

Dokümanın Adı:
Güvenli Sistem Mühendisliği Prensipleri

Gizlilik Derecesi: Tüm Kullanıcılar	Doküman No: BİL.PR01	İlk Yayın Tarihi 13.07.2018	Revizyon Tarihi 10.04.2023	Revizyon No: 1	Sayfa Sayısı: 1/6
--	---------------------------------------	--	---	---------------------------------	------------------------------------

REVİZYON TARİHÇESİ

Revizyon No	Revizyon Tarihi	Açıklama
1	10.04.2023	- Doküman güncel Şablona uygun olarak güncellenmiştir. - “3. DAYANAK Bu prensip; ISO 27001 Bilgi Güvenliği Yönetim Sistemleri Standardına dayanılarak hazırlanmıştır.” Maddesi eklenmiştir. Bu nedenle sıralama değişmiştir. (1.AMAÇ 2. KAPSAM 3. DAYANAK) - 3.TANIMLAR VE KISALTMALAR (eski) başlığı 4. TANIMLAR VE KISALTMALAR olarak değişmiştir. - Tanımlar başlığında, (eski 3.7) Güvenli Sistem Mühendisliği Prensipleri Formu sistemlere ilişkin tüm talepler ITSM aracından alındığından kullanımdan kaldırılmıştır. - Tanımlar başlığında, (yeni 4.14) makam onayı ile merkez ifadeleri kaldırıldığı için Merkez Müdürlükleri ifadesi PTT Müdürlükleri olarak değiştirilmiştir. - Doküman içerisinde geçen PTT A.Ş. ifadesi TDK’ya göre PTT AŞ olarak güncellenmiştir. - Uygulama başlığı (yeni 6.) altındaki (eski 5.1.2 ve eski 5.2.3) Yazılım Talebi Tasarım ve Değerlendirme Formu ile Güvenli Sistem Mühendisliği Prensipleri Formu kullanılmadığı için kaldırılmıştır. - Uygulama başlığı (yeni 6.) altındaki (yeni 6.1.3, 6.3.2, 6.5.2) maddelerine ç bendi eklendiğinden sıralama değişmiştir. - Uygulama başlığı (yeni 6.) altındaki (eski 5.5.1) (yeni 6.5.1) “Bilgi sistemlerinin ve bu sistemler tarafından işlenen, transfer edilen ve bilginin yetkisiz değiştirilmesi, yok edilmesi, eksik iletimi yanlış yönlendirmeyi, yetkisiz mesaj değiştirmeyi, yetkisiz ifşayı, yetkisiz mesaj çoğaltmayı önlemek ve erişilebilirliğinin zarar görmemesini garanti altına almak adına bilgi ile ilişkili riskler, EYS.PR20 EYS Risk ve Fırsatların Yönetimi Prosedürüne uygun olarak yönetilir.” olarak güncellenmiştir. - Uygulama başlığı (yeni 6.) altındaki (yeni 6.5.2)’nin c maddesi “Bilgi sistemlerine yönelik faaliyetlerin, ayrıcalıkların ve bilgi güvenliği olaylarının kayıt edilmesi, ileride yapılabilecek soruşturmalar ve erişim kontrolünü izlemeye yardımcı denetim mekanizmalarının uygulanması: BT.D.PK07 Erişim Kontrol Politikası ile şirketin bilgi sistemlerine hangi kurallar ve şartlar dâhilinde, hangi öznelere, hangi yetki ve imtiyazlarla erişebileceği bir esasa bağlanır. Kritik bilgi sistemlerine yapılan tüm başarısız erişim girişimlerinin tarih, zaman ve erişilen kaynağın detayı ile ilgili bilgilerin kayıtları BT.D.PR01 Log Yönetim Prosedürüne göre tutulur. Öznelerin kritik bilgi sistemleri üzerinde hangi işlemleri yaptıklarının veya hangi nesnelere eriştiklerinin bilinmesi ve gözlenebilmesi sağlanır.” Olarak güncellenmiştir. - Uygulama başlığı (yeni 6.) altındaki (yeni 6.5.2)’nin e maddesi “Veri

Hazırlayan: BİLİŞİM DAİRE BAŞKANLIĞI	Süreç Sahibi: BİLİŞİM DAİRE BAŞKANLIĞI DAİRE BAŞKANI	EYS Onayı ENTEĞRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	Kontrol HUKUK MÜŞAVİRLİĞİ HUKUK MÜŞAVİRLİĞİ I. HUKUK MÜŞAVİRİ	Onaylayan / İdari GENEL MÜDÜR
--	--	--	--	---

Dokümanın Adı:
Güvenli Sistem Mühendisliği Prensipleri

Gizlilik Derecesi: Tüm Kullanıcılar	Doküman No: BİL.PR01	İlk Yayın Tarihi 13.07.2018	Revizyon Tarihi 10.04.2023	Revizyon No: 1	Sayfa Sayısı: 2/6
		güvenliğinin sağlanması: Bilgi sistemleri geliştirmelerine yönelik kaynak kodlarına erişim, ilgili projenin geliştirme ekibi ve yedeklemeden sorumlu sistem yöneticileri ile sınırlı tutulur. Uygulamalar tarafından kullanılan gerçek verilere yalnızca veritabanı yöneticilerinin ve yedeklemeden sorumlu sistem yöneticilerinin BTD.TL08 Erişim Yönetim Talimatı gereğince erişimine imkân verilir. Üretim ortamında kullanılan gerçek veriler ile test yapılmaz. Testler test verileri ile gerçekleştirilir. Test verileri, BİL.TL25 Güvenli Yazılım ve Sistem Geliştirme Talimatında belirtildiği gibi üretim ortamından ve “temizlenerek” test ortamına alınan veriler olabileceği gibi doğrudan yapay olarak üretilmiş veriler de olabilir. “ olarak güncellenmiştir. - (yeni 7.) Onay başlığı altına “Bu Talimat Genel Müdür tarafından onaylanır” eklenmiştir. Bu doğrultuda alt maddelerin sıra numarası değişmiştir. (8. YÜRÜRLÜK 9. YÜRÜTME 10. REFERANS DOKÜMANLAR) - Referans Dokümanlar (yeni 10.) başlığı altına ISO 27001 Bilgi Güvenliği Yönetim Sistemleri Standardı eklenmiştir. Mevcut referansların kodları eklenmiştir.			
0	13.07.2018				

Hazırlayan: BİLİŞİM DAİRE BAŞKANLIĞI	Süreç Sahibi: BİLİŞİM DAİRE BAŞKANLIĞI DAİRE BAŞKANI	EYS Onayı ENTEGRE YÖNETİM SİSTEMİ DAİRE BAŞKANLIĞI DAİRE BAŞKANI	Kontrol HUKUK MÜŞAVİRLİĞİ HUKUK MÜŞAVİRLİĞİ I. HUKUK MÜŞAVİRİ	Onaylayan / İdari GENEL MÜDÜR
---	--	---	---	---

Doküman No
BİL.PR01.1

2/6

10.04.2023

1. AMAÇ

Bu dokümanın amacı Posta ve Telgraf Teşkilatı Anonim Şirketi bünyesindeki güvenli sistemlerin tasarlanmasını ve işletilmesini sağlamak için Güvenli Sistem Mühendisliği Prensipleri ile ilgili usul ve esaslarla yetki ve sorumlulukları belirlemektir.

2. KAPSAM

Bu prensipte belirtilen ve uyulması gereken hususlar Posta ve Telgraf Teşkilatı Anonim Şirketi'ndeki tüm bilgi sistemleri ve bilgi güvenliği ile ilgili Usul ve Esaslar dâhilinde Posta ve Telgraf Teşkilatı Anonim Şirketi'ndeki tüm birimleri ve çalışanları kapsar.

3. DAYANAK

Bu prensip, ISO 27001 Bilgi Güvenliği Yönetim Sistemleri Standardına dayanılarak hazırlanmıştır.

4. TANIMLAR VE KISALTMALAR

4.1 Amaç: Şirketin erişmeye çalıştığı uzun dönemli genel sonuçtur. Strateji oluşumuna temel teşkil eder ve planların gerçekleştirilmesinde yol göstericidir.

4.2 BGYS: ISO 27001 Bilgi Güvenliği Yönetim Sistemidir.

4.3 Birim: Komite/Kurul, Başkanlık, Müşavirlik, Daire Başkanlığı, Birimler, Özel Kalem Müdürlüğü ve Başmüdürlüklerdir.

4.4 Birim Üst Yöneticisi: Merkez Teşkilatında Komite/Kurul Başkanını, Başkanı, 1. Hukuk Müşavirini, Daire Başkanını, Birim Sorumlusunu ve Özel Kalem Müdürünü; Taşra Teşkilatında ise Başmüdürdür.

4.5 Birim Yöneticisi: Merkez Teşkilatında Şube/Teknik Müdürleri, Taşra Teşkilatında ise Teknik Müdürleri/Müdürleri (İhtisas) ve PTT Müdürleridir.

4.6 Form: Usul ve Esaslar ile talimatlarda anlatılan işleri destekleyen, işlerin kim tarafından, ne zaman ve nasıl yapıldığının kaydedildiği dokümandır.

4.7 Güvenli Sistem Mühendisliği: Güvenliği; ağ sistemleri, sunucu sistemleri, veri tabanları, uygulama ve güvenlik sistemlerinden oluşan bilgi sistemleri süreçlerinin tamamını bir parçası olarak kabul eden ve bütünsel bir bakış açısı sunan sistem mühendisliği yaklaşımıdır.

4.8 Log: Meydana gelen olayların ve hareketlerin kayıt altına alındığı dosyalardır.

4.9 Log Yönetim Talimatı: Bilgi Teknolojileri sistemlerinde oluşan kritik sistemlere ait logların toplanmasının, takibinin ve yönetiminin nasıl yapılacağını açıklayan dokümandır.

4.10 Merkez Teşkilatı: Şirketin Genel Müdürlük birimleridir.

4.11 Ölçme: Bir değerin tayini için gerçekleştirilen süreçtir.

4.12 Performans: Ölçülebilir sonuçtur.

4.13 Prosedür: Şirketi uygulamakta olduğu/uygulayacağı süreçleri etkileyen tüm aktivitelerle ilgili olarak sorumlularını, iş akışlarını, bölümler arası ilişkileri belirleyen, kullanılacak formları ve talimatları açıklayan usul ve esaslardır. Prosedür, yürütülen faaliyetin amacı, kapsamı, sorumluları, uygulama alanı ve ilgili dokümanlar tanımlanarak hazırlanır. Prosedür; ne, nasıl, neden, nerede, ne zaman yapılacak, kim tarafından hangi yöntemle kontrol edilecek ve değerlendirilecek, nasıl kaydedilecek ve izlenecek sorularının yanıtlarını açık ve kısa olarak belirtir.

4.14 PTT Müdürlükleri: Taşra Teşkilatında Teknik Müdürlükler/Müdürlükler (İhtisas) dışında kalan müdürlüklerdir.

4.15 Şirket/PTT AŞ: Posta ve Telgraf Teşkilatı Anonim Şirketi'dir.

4.16 Taşra Teşkilatı: Şirketin Genel Müdürlük birimleri dışındaki tüm birimleridir.

4.17 Teknik Müdürlükler/Müdürlükler (İhtisas): Taşra Teşkilatında PTT Müdürlükleri (PDM, PİM, KİM, vb.) dışında kalan Başmüdürlüklere bağlı müdürlüklerdir.

4.18 Zafiyet (Penetrasyon) Testi: Sistemlerde güvenlik açığı bulunup bulunmadığını tespit etmeye yönelik çeşitli araçlar kullanılarak yapılan tarama testleridir.

5. SORUMLULUKLAR

Bu prensibin uygulanmasından öncelikle PTT AŞ Bilgi Teknolojileri Daire Başkanlığı ve Bilişim Daire Başkanlığı yönetimi ve tüm çalışanları sorumludur. Bütün çalışanlar bilgi işlem faaliyetlerinin tüm aşamalarında bu prensibe uygun hareket etmekle yükümlüdür.

6. UYGULAMA

6.1 Tasarım Aşaması İçin Temel Güvenlik Gereksinim Kriterlerinin Belirlenmesi

6.1.1 Tüm bilgi sistemleri geliştirme projeleri, gereksinimlerin tespiti aşaması ile başlatılır. Gereksinimlerin belirlenmesi aşamasında uygulamaların güvenlik gereksinimleri ile yazılımların kimlik doğrulama (authentication), yetkilendirme (authorization) ve yetki yönetimi (authorization management) ile kayıt tutma gereksinimleri BİL.TL25 Güvenli Yazılım ve Sistem Geliştirme Talimatı ve BİL.PK01 Güvenli Yazılım ve Sistem Geliştirme Politikası'na göre tanımlanır.

6.1.2 Tasarım bileşenleri, bileşenler arasındaki ara yüzler, dış sistemler ile geliştirilecek sistem arasındaki ara yüzler, satın alınacak hazır ürünler ya da alt yüklenici tarafından geliştirilecek bileşenler ile ilgili kararlar tasarım aşamasında verilmekte olup, tasarım kısıtları ortaya çıkarılır. Oluşturulan tasarım bileşenleriyle ilgili gereksinimler eşleştirilir.

6.1.3 Mimari yapı oluşturulurken kabul gören tasarım standartlarından yararlanılır. Bu faaliyetlerin sonucunda:

- a) Tasarım modelleri oluşturulur. (Akış süreçleri, Ağ topolojisi vs. oluşturulur.)
- b) Mimari ve tasarım arasında gereksinimler ve izlenebilirlik oluşturulur.
- c) Teknik riskler tanımlanır, gerekirse Proje Yönetim Planı güncellenir.
- ç) Entegrasyon için genel kriterler belirlenir.
- d) Çözümün mantıksal, fiziksel ve veri yapısı oluşturulur.

6.2 Tasarım Değerlendirme

6.2.1 Faaliyetlerin başarılı bir şekilde uygulanması sonucunda, değişikliklerin kolayca tasarıma yansıtılabildiği, test sonucunda tasarıma bağlı hataların sürecin önceki sürümlerine göre azaldığı sonuçların alınması hedeflenir.

6.2.2 Tasarımın değerlendirilmesi aşamasında esneklik, güvenilirlik, güvenlik, test edilebilirlik ve bakım kolaylığı, performans gibi kalite kriterleri kullanılır.

6.3 Güvenlik Gereksinimlerinin, Tüm Sistem Tasarım Sürecinin Ayrılmaz Bir Parçası Olarak Göz Önünde Bulundurulması

6.3.1 Bilgi sistemleri tasarım aşamasında güvenlik gereksinimleri, tüm sistem tasarım sürecinin ayrılmaz bir parçası olarak göz önünde bulundurulur.

6.3.2 Bu aşamada gereksinimlerin tasarım modeliyle doğru ve kaliteli bir şekilde karşılandığı ve güvenlik gereksinimlerini sağlamakta olduğu kontrol edilir. Tasarımın,

- a) Modüler,
- b) Test edilebilir,
- c) Bakımı kolay,
- ç) Kullanımı elverişli,
- d) Güvenilir,
- e) Performans sorunu olmayan,

f) Güvenlik açığı olmayan bir tasarım olması beklenir.

6.3.3 Tüm gereksinimlerin tasarımıyla karşılandığı ve tasarımın gereksinimlerini sağladığının doğrulanması amacıyla kabul testleri gerçekleştirilir.

Güvenlik kriterlerinin belirlenmesi sayesinde tasarım aşamasında potansiyel tehditler EYS.PR20 EYS Risk ve Fırsatların Yönetim Prosedürü'ne göre tespit edilerek bilgi sistem açıklıklarına yönelik aksiyonlar alınır ve bu sayede daha ileri fazlarda farkına varılan açıklıklara göre daha az maliyetli bir çalışma sağlanmış olur.

6.4 Bilgi Sistemlerine Yönelik Geliştirme Çalışmaları Yapan Kişilerin Güvenli Sistem Geliştirme Konusunda Yeterli Düzeyde Bilgi Seviyesine Sahip Olması

Bilgi sistemlerine yönelik geliştirme çalışmaları yapan çalışanların güvenli sistem geliştirme konusunda (tasarım, geliştirme, konfigürasyon kontrolü, entegrasyon ve test faaliyetlerine yönelik mühendislik disiplinleri) yeterli düzeyde bilgi seviyesine sahip olmasını garanti altına alacak eğitimler Bilgi Teknolojileri Daire Başkanlığı ve Bilişim Daire Başkanlığı kararı ile belirlenir ve bu kapsamdaki eğitim faaliyetleri EGT.PR01 Eğitim Prosedürü doğrultusunda organize edilir.

6.5 İşlenen, İletilen ve Depolanan Bilginin Korunması

6.5.1 Bilgi sistemlerinin ve bu sistemler tarafından işlenen, transfer edilen ve bilginin yetkisiz değiştirilmesi, yok edilmesi, eksik iletimi yanlış yönlendirmeyi, yetkisiz mesaj değiştirmeyi, yetkisiz ifşayı, yetkisiz mesaj çoğaltmayı önlemek ve erişilebilirliğinin zarar görmemesini garanti altına almak adına bilgi ile ilişkili riskler, EYS.PR20 EYS Risk ve Fırsatların Yönetimi Prosedürü'ne uygun olarak yönetilir.

6.5.2 İç ya da dış kaynaklar tarafından gerçekleştirilen her türlü bilgi sistemleri geliştirme faaliyetinde girdi, veri transferi, işlem ve çıktı kontrolleri ile verilerin tamlığının, kullanılabilirliğinin ve ihtiyaç duyulan seviyede güvenliğinin sağlanması amacıyla uygulanacak kurallar Üçüncü Taraflarla Yapılan Teknik Şartnameler ve EYS.FR22 Üçüncü Taraf Bilgi Koruma Taahhütnamesi'ne uygun olarak aşağıda tanımlanmıştır;

a) Potansiyel tüm saldırılara karşı yeterli güvenlik seviyesinin sağlanması: Güvenlik kontrollerinin belirlenmesi aşamasında olası zararlı kod enjeksiyonu, işletim sistemi komut enjeksiyonu, arka kapı açıkları, hizmet dışı bırakma, aktif ve pasif dinleme gibi potansiyel saldırı türleri göz önünde bulundurulur.

b) Erişim yetkilendirmesine ihtiyaç duyulmayan sistemlerin kritik hassas sistemlerden izole edilmesi: Hassas sistemlerin yalıtılmış bir bilgi işlem ortamına sahip olması sağlanır. LTD.PK07 Erişim Kontrol Politikası ile LTD.AŞ bilgi varlıklarına sadece yetkili kişi veya grupların EYS.PR19 Varlık Yönetim Prosedürü ve LTD.TL08 Erişim Yönetimi Talimatı'nda tanımlanan haklar dâhilinde erişilmesi sağlanır.

c) Bilgi sistemlerine yönelik faaliyetlerin, ayrıcalıkların ve bilgi güvenliği olaylarının kayıt edilmesi, ileride yapılabilecek soruşturmalar ve erişim kontrolünü izlemeye yardımcı denetim mekanizmalarının uygulanması: LTD.PK07 Erişim Kontrol Politikası ile şirketin bilgi sistemlerine hangi kurallar ve şartlar dâhilinde, hangi öznelerin, hangi yetki ve imtiyazlarla erişebileceği bir esasa bağlanır. Kritik bilgi sistemlerine yapılan tüm başarısız erişim girişimlerinin tarih, zaman ve erişilen kaynağın detayı ile ilgili bilgilerin kayıtları LTD.PR01 Log Yönetim Prosedürü'ne göre tutulur. Öznelerin kritik bilgi sistemleri üzerinde hangi işlemleri yaptıklarının veya hangi nesnelere eriştiklerinin bilinmesi ve gözlenebilmesi sağlanır.

ç) Ayrıcalıkların tahsisi, kullanımının sınırlandırılması ve kontrolünün sağlanması: Özel olarak yetkilendirme yapılmadığı sürece kullanıcılara tüm bilgi sistemlerine erişim hakkı verilmemekte olup, sadece iş sorumluluklarını veya iş gereksinimlerini yerine getirmelerine yetecek kadar izin verilir. Ayrıcalıkların yönetimi, LTD.TL08 Erişim Yönetim Talimatı'nda yer alır.

d) Hesap verilebilirliğin garanti altına alınması için benzersiz kullanıcı kimliklerinin kullanılması: LTD.AŞ bünyesinde gerçekleştirilmekte olan erişim kontrolü, kimlik doğrulama (authentication), yetkilendirme (authorization) ve hesap verebilirlik (accountability) kavramlarını içine almaktadır. Her kullanıcının kendine ait ve kendisini benzersiz olarak tanımlayan bir kullanıcı hesabı bulunmakta olup, tüm kullanıcı hesaplarına ait bir parolanın olması sağlanır.

e) Veri güvenliğinin sağlanması: Bilgi sistemleri geliştirmelerine yönelik kaynak kodlarına erişim, ilgili projenin geliştirme ekibi ve yedeklemeden sorumlu sistem yöneticileri ile sınırlı tutulur. Uygulamalar tarafından kullanılan



gerçek verilere yalnızca veri tabanı yöneticilerinin ve yedeklemeden sorumlu sistem yöneticilerinin BTD.TL08 Erişim Yönetim Talimatı gereğince erişimine imkân verilir. Üretim ortamında kullanılan gerçek veriler ile test yapılmaz. Testler test verileri ile gerçekleştirilir. Test verileri, BİL.TL25 Güvenli Yazılım ve Sistem Geliştirme Talimatı'nda belirtildiği gibi üretim ortamından ve “temizlenerek” test ortamına alınan veriler olabileceği gibi doğrudan yapay olarak üretilmiş veriler de olabilir.

f) Sistemin Devreye Alınması: Tasarımı gerçekleştirilen sistemler BTD.PR07 Bilgi Sistemi Temini Geliştirilmesi ve Bakımı Prosedürü'ne göre devreye alınır. Yazılımlar ise BİL.TL25 Güvenli Yazılım ve Sistem Geliştirme Talimatı'na göre devreye alınır. Test ve kontroller sağlanmadan sistemler devreye alınmaz.

7. ONAY

Bu prensip Genel Müdür tarafından onaylanır.

8. YÜRÜRLÜK

Bu prensip yayımlandığı tarihte yürürlüğe girer.

9. YÜRÜTME

Bu prensibi Genel Müdür yürütür.

10. REFERANS DOKÜMANLAR

BİL.PK01-Güvenli Yazılım ve Sistem Geliştirme Politikası

BTD.PK07-Erişim Kontrol Politikası

EGT.PR01-Eğitim Prosedürü

EYS.PR19-Varlık Yönetim Prosedürü

EYS.PR20-EYS Risk ve Fırsatların Yönetimi Prosedürü

STD.004-TS EN ISO-IEC 27001 Bilgi Güvenliği Yönetim Sistemi Standardı

BTD.PR07-Bilgi Sistemi Temini Geliştirilmesi ve Bakımı Prosedürü

BTD.TL08-Erişim Yönetimi Talimatı

EYS.FR22-Üçüncü Taraf Bilgi Koruma Taahhütnamesi

BİL.TL25-Güvenli Yazılım ve Sistem Geliştirme Talimatı